Understanding the Threat Landscape of Remote Cloud Storage

ECE239AS

(Made by Katherine Izhikevich)

“Origins” of a Data Breach

Zero Day

Phishing Attack

Stolen Credential

“Origins” of a Data Breach

Zero Day

Phishing Attack

Stolen Credential

Unintentional Exposure

- Using a resource that seems to work as intended, but is vulnerable in practice.
- Think: using `1234` as a password.

Data leaks happen all the time

Aston Villa Football Club leaks members' data

21 May 2024 Chris Price Cybersecurity

Aston Villa Football Club (AVFC) left a publicly leaking Amazon Web Services (AWS) S3 bucket containing the personally identifiable information of 135,770 individuals. The affected fans are vulnerable to spear phishing, social engineering attacks, and identity theft attempts.

Data leaks happen all the time

India's national logistics portal exposed sensitive personal data, trade records

Jagmeet Singh / 4:45 AM PDT • October 2, 2023

"... Exposed data included full names, nationality, date of birth, gender, passport numbers, ..."

Data leaks happen all the time

Lantum S3 bucket leak is prescription for chaos for thousands of UK doctors

Lindsay Clark Mon 12 Jun 2023 // 12:34 UTC

"... exposed personal details relating to 3,200 individuals via unsecured S3 buckets… including passport details… medical documents …

Data leaks happen all the time

A Cyberattack Illuminates the Shaky State of Student Privacy

At a moment when education technology firms are stockpiling sensitive information on millions of school children, safeguards for student data have broken down.

By Natasha Singer

July 31, 2022

6 MIN READ

Data leaks happen all the time

A Cyberattack Illuminates the Shaky State of Student Privacy

At a moment when education technology firms are stockpiling sensitive information on millions of school children, safeguards for student data have broken down.

By Natasha Singer
July 31, 2022

6 MIN READ

Microsoft leaked 2.4TB of data belonging to sensitive customer. Critics are furious

Data includes signed contracts and projects related to critical infrastructure.

DAN GOODIN - 10/20/2022, 4:03 PM

Data leaks happen all the time

A Cyberattack Illuminates the Shaky State of Student Privacy

At a moment when education technology firms are stockpiling sensitive information on millions of school children, safeguards for student data have broken down.

By Natasha Singer
July 31, 2022

6 MIN READ

Microsoft leaked 2.4TB of data belonging to sensitive customer. Critics are furious

Data includes signed contracts and projects related to critical infrastructure.

DAN GOODIN - 10/20/2022, 4:03 PM

A huge data leak of 1 billion records exposes China's vast surveillance state

One billion resident records were allegedly siphoned from a police database

Zack Whittaker, Carly Page / 1:15 PM EDT • July 7, 2022

Comment

Data leaks happen all the time

A Cyberattack Illuminates the Shaky State ... vacy

At a moment when education technology firms are stock ... ions of school children, safeguards for student data have broken down.

By Natasha Singer
July 31, 2022

6 MIN READ

Micros ... ata belonging to ser ... tics are furious

... s related to critical infrastructure.

A ... a leak of 1 billion records exposes C ... vast surveillance state

One ... ion resident records were allegedly siphoned from a police database

Zack Whittaker, Carly Page / 1:15 PM EDT • July 7, 2022

Comment

Insecure Amazon S3 bucket exposed personal data on 500,000 Ghanaian graduates

John Leyden 06 January 2022 at 10:58 UTC
Updated: 10 January 2022 at 09:40 UTC

Data leaks happen all the time

A Cy ack Illuminates the Shaky State vacy

At a m chnology firms are stock ions of school children, safeguards for stude

By Na

July 3

6 MIN READ

Micros a belonging to ser ious

Sennheiser exposed personal data of 28,000 customers with leaky S3 bucket

Server containing full names, email addresses, phone numbers, and supplier information was left open to the public for three years

by: Danny Bradbury 16 Dec 2021

et exposed anaian

Insecure Am personal data o graduates

John Leyden 06 January 2022 at 10:58 UTC
Updated: 10 January 2022 at 09:40 UTC

A a leak of 1 billion recor es C vast surveillance state

One ion resident records were allegedly siphoned from a police database

Zack Whittaker, Carly Page / 1:15 PM EDT • July 7, 2022

Comment

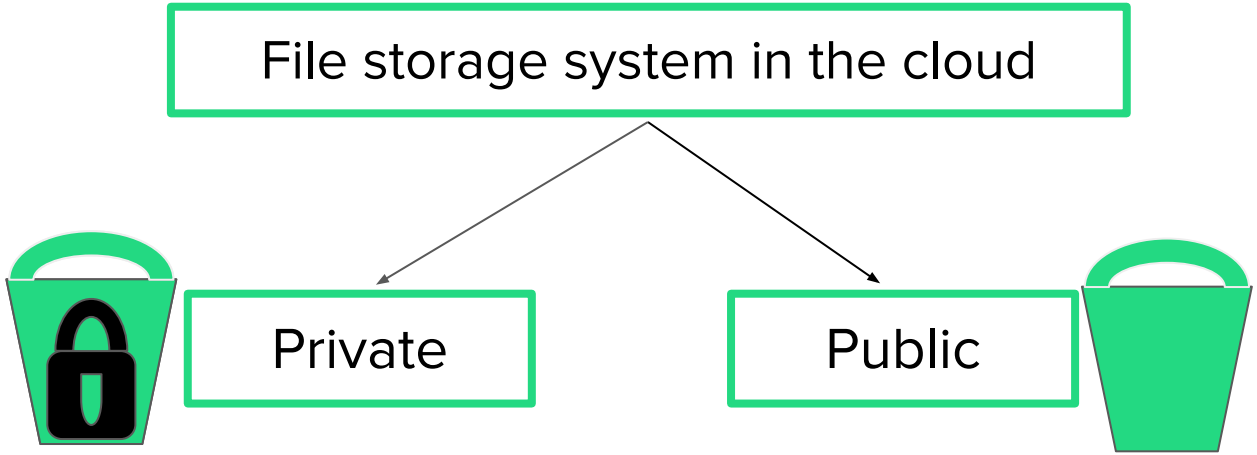
Data leaks happen all the time

Data leaks happen all the time

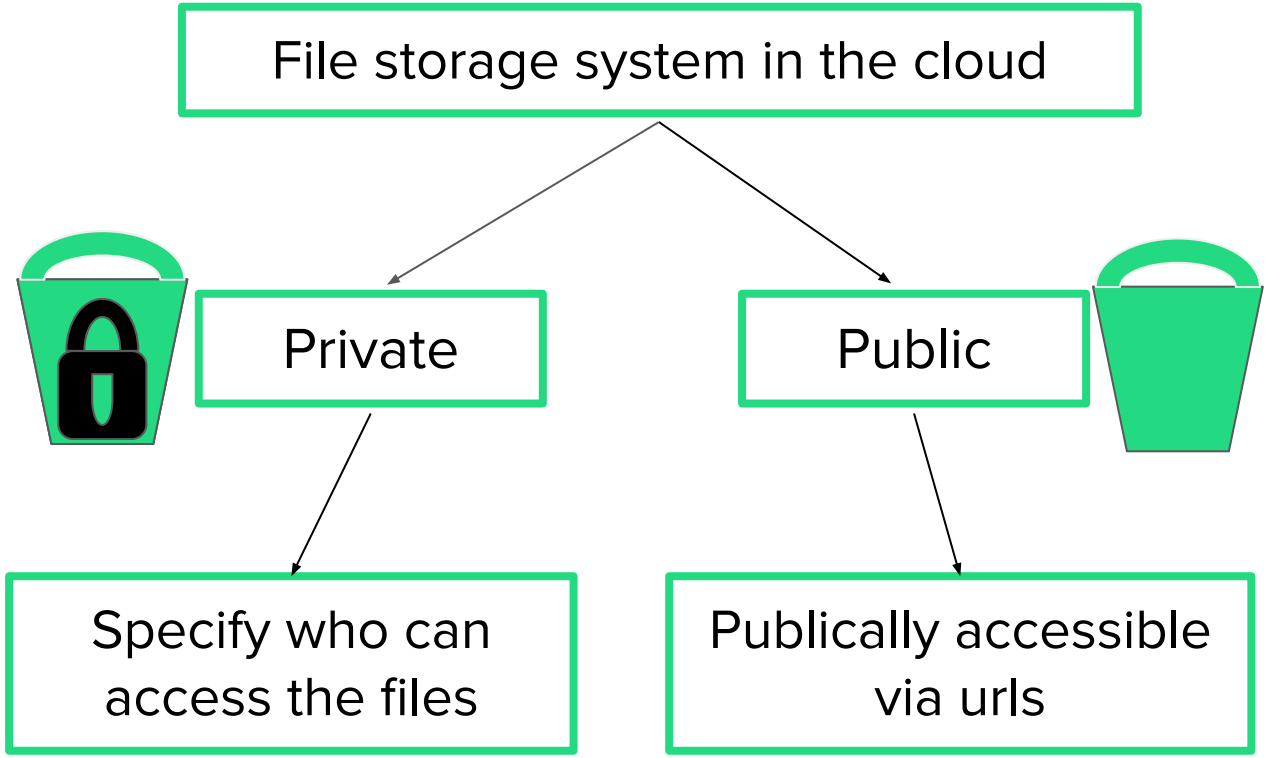
What is a bucket?

File storage system in the cloud

What is a bucket?



What is a bucket?



Private buckets store sensitive information

File storage system in the cloud

Private

Specify who can access the files

Storing sensitive information about customers

Private buckets store sensitive information

File storage system in the cloud

Private

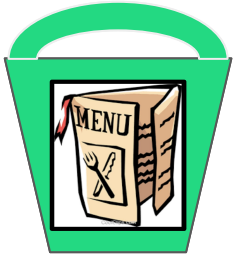
Specify who can access the files

Employees, contractors

Storing sensitive information about customers

Public buckets host public information

File storage system in the cloud



Public

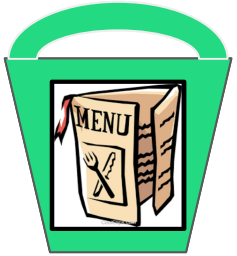
Publically accessible via urls

Public buckets host public information

File storage system in the cloud

Public

Publically accessible via urls



https://**myrestaurant**.s3.us-west-2.amazonaws.com

Public buckets can be configured as a website

https://**mywebsite**.s3.us-west-2.amazonaws.com

Publically accessible
via this url

Creative Freedom to Name Buckets

- Alphanumeric, lowercase only, dashes allowed
- Length 3-63
- Must be an unused/unique name - no repository exists

Creative Freedom to Name Buckets

- Alphanumeric, lowercase only, dashes allowed
- Length 3-63
- Must be an unused/unique name - no repository exists
- Examples of valid bucket names (that are available)!
  - thebigtoe
  - 3140ebu3b
  - you-get-the-point

Creative Freedom to Name Buckets

- Alphanumeric, lowercase only, dashes allowed
- Length 3-63
- Must be an unused/unique name - no repository exists
- Examples of valid bucket names (that are available)!
  - thebigtoe
  - 3140ebu3b
  - you-get-the-point
- Astronomical number of possible bucket names: ~10^{101}

Cloud Providers Offering Bucket Service

Cloud Providers Offering Bucket Service

Simple Storage Service

Bucket Recap

File storage system in the cloud with a unique name

Private

Public

Specify who can access the files

Publically accessible via urls

Attackers exploit public buckets meant to be private

File storage system in the cloud with a unique name

Private

Public

Specify who can access the files

Publically accessible via urls

Researchers explore “leaky” cloud infrastructure

ACSAC ‘18

There’s a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Seminal study, guessing bucket names, finding exposed data in s3

RAID ‘21

Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

Zakir Durumeric
Stanford University

Faster, ML-based bucket name generator across s3, GCP, and Alibaba

EuroS&P ‘24

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

Katherine Izhikevich
UC San Diego

Geoffrey M. Voelker
UC San Diego

Stefan Savage
UC San Diego

Liz Izhikevich
Stanford University

Deploying honeypots to understand threat landscape of exposures

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

$

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

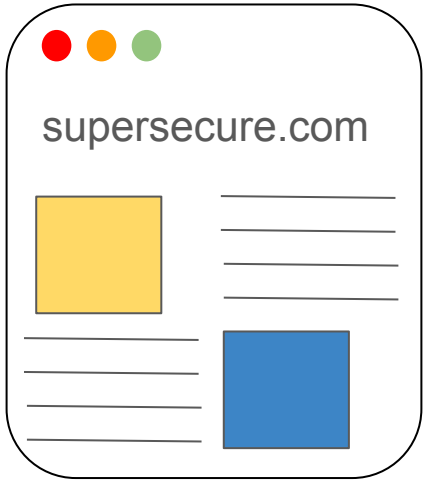
Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*



The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

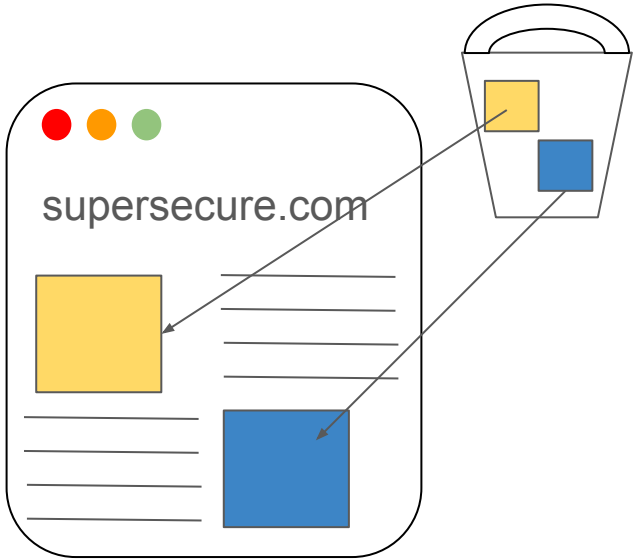
Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*



The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

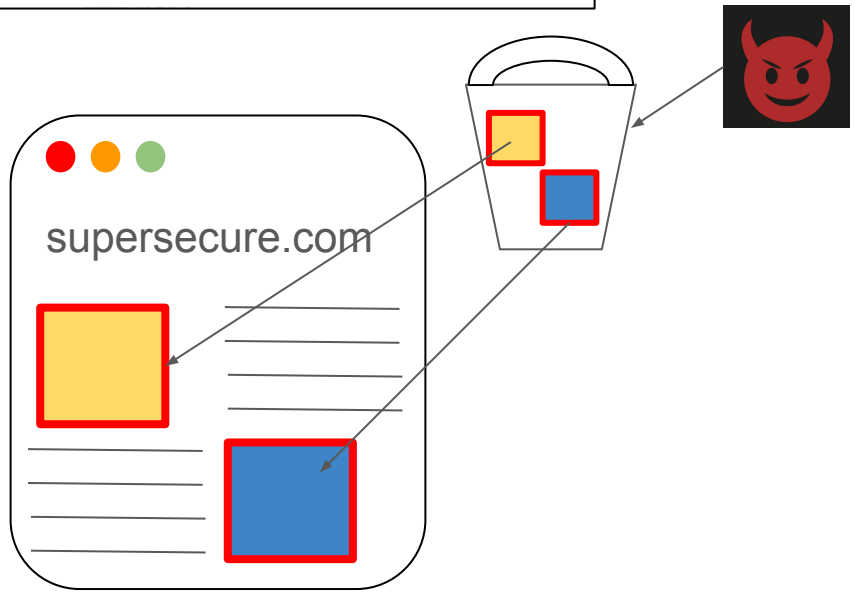
Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*



The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

supersecure.com

assets.supersecure.com

↓

assets-supersecure.
s3.amazonaws.com

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

supersecure.com

assets.supersecure.com

↓

assets-supersecure.
s3.amazonaws.com

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

supersecure.com

assets.supersecure.com

↓

assets-supersecure.
s3.amazonaws.com

The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

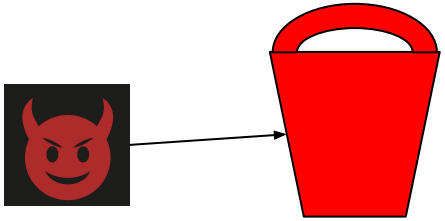
Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

supersecure.com

assets.supersecure.com

↓

assets-supersecure.
s3.amazonaws.com



The Bucket Threat Model

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model

Readable Buckets	- *Data leakage*
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*
Unclaimed Buckets	- *Dangling Subdomain Takeover*

How many buckets are vulnerable to these threats?

Method for Generating Bucket Names

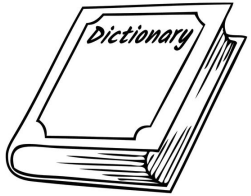
There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

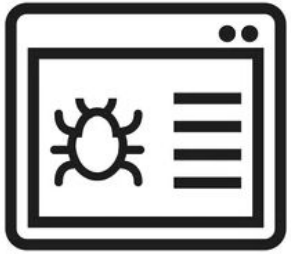
Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

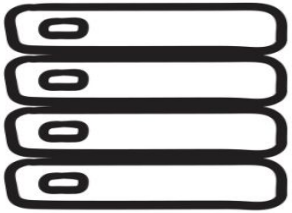
Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it





PublicWWW

Passive DNS



Method for Generating Bucket Names

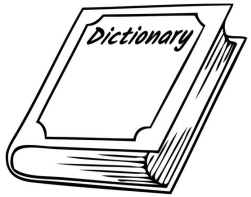
There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

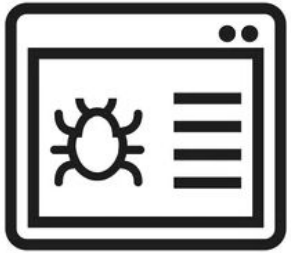
Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

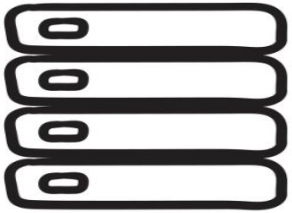
Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

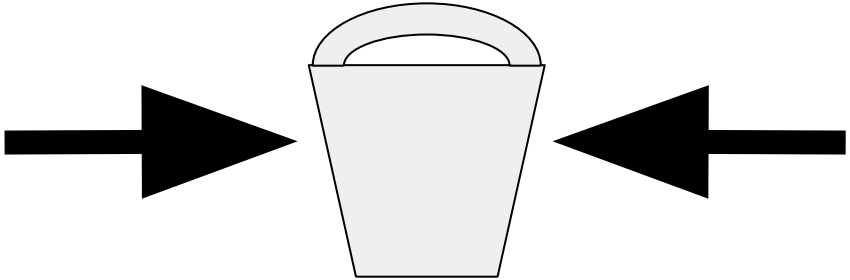




PublicWWW

Passive DNS





Vulnerable Buckets

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model		Results
Readable Buckets	- *Data leakage*	$\frac{\sim 27000}{240000}$ = 11% buckets vulnerable
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*	$\frac{214}{240000}$ = 0.09% buckets vulnerable
Unclaimed Buckets	- *Dangling Subdomain Takeover*	$\frac{13}{7627}$ = 0.17% websites vulnerable

Vulnerable Buckets

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella* — UC Santa Barbara — conand@cs.ucsb.edu
Mario Polino — Politecnico di Milano — mario.polino@polimi.it
Marcello Pogliani — Politecnico di Milano — marcello.pogliani@polimi.it
Stefano Zanero — Politecnico di Milano — stefano.zanero@polimi.it

Threat Model		Results
Readable Buckets	- *Data leakage*	$\frac{\sim 27000}{240000}$ = 11% buckets vulnerable
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*	$\frac{214}{240000}$ = 0.09% buckets vulnerable
Unclaimed Buckets	- *Dangling Subdomain Takeover*	$\frac{13}{7627}$ = 0.17% websites vulnerable

4 months to generate 240000

Open Questions from Continella et al.

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

- Are there better techniques (e.g., faster, higher hitrate) to find more buckets, such as machine learning?
- What about: amazon S3, Google Cloud, Alibaba Cloud, IBM Cloud, ORACLE CLOUD, Microsoft Azure

Open Questions from Continella et al.

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

- Are there better techniques (e.g., faster, higher hitrate) to find more buckets, such as machine learning?
- What about: amazon S3, Google Cloud, Alibaba Cloud, IBM Cloud, ORACLE CLOUD, Microsoft Azure

Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

Zakir Durumeric
Stanford University

Researchers Leverage Password-Cracking

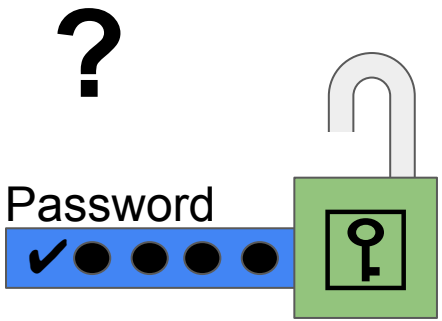
Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

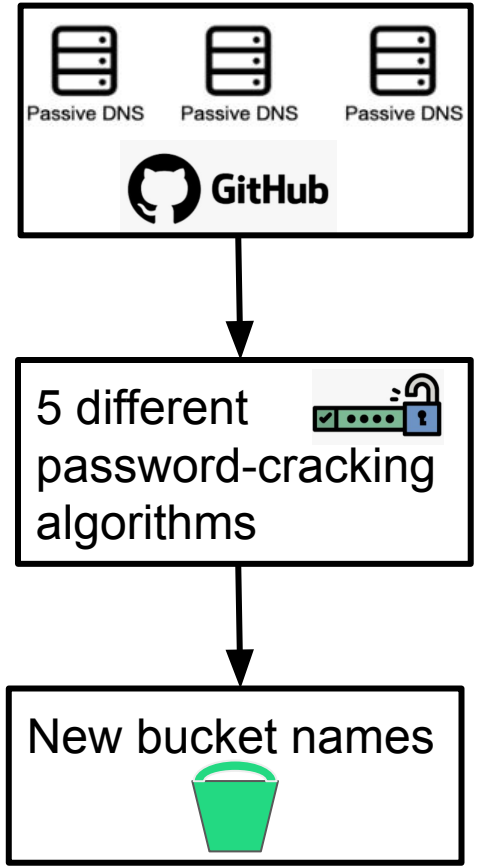
Liz Izhikevich*
Stanford University

Zakir Durumeric
Stanford University



https://**1234**.s3.us-west-2.amazonaws.com

Researchers Leverage Password-Cracking



Stratosphere: Finding Vulnerable Cloud Storage Buckets

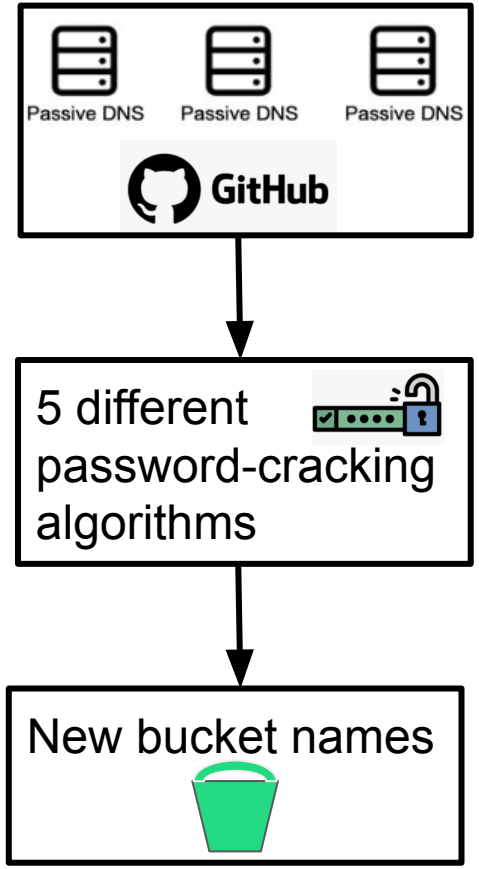
Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

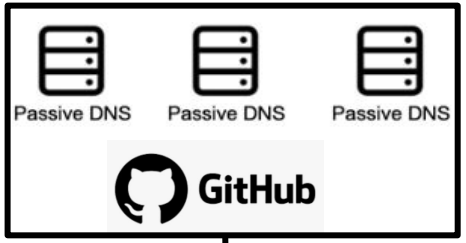
Zakir Durumeric
Stanford University

Researchers explore “leaky” cloud infrastructure



Buckets	GCP	Alibaba	s3
# Generated	≥ 40M		
# Existing	~128000	215	~37000
# Public	~13500	123	~25500
# Sensitive	~1060		

Researchers explore “leaky” cloud infrastructure



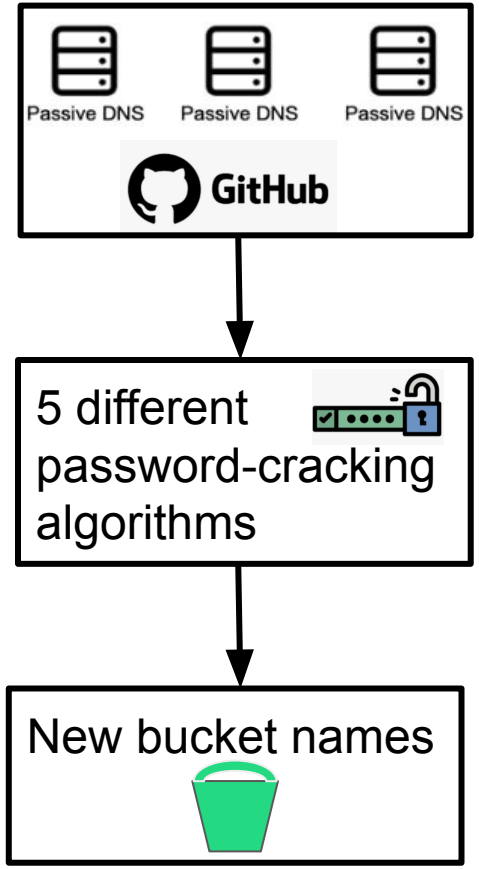
5 different password-cracking algorithms

New bucket names

Buckets	GCP	Alibaba	s3
# Generated	≥ 40M		
# Existing	~128000	215	~37000
# Public	~13500	123	~25500
# Sensitive	~1060		

Analyze patterns & complexity of bucket names & likelihood of vulnerability

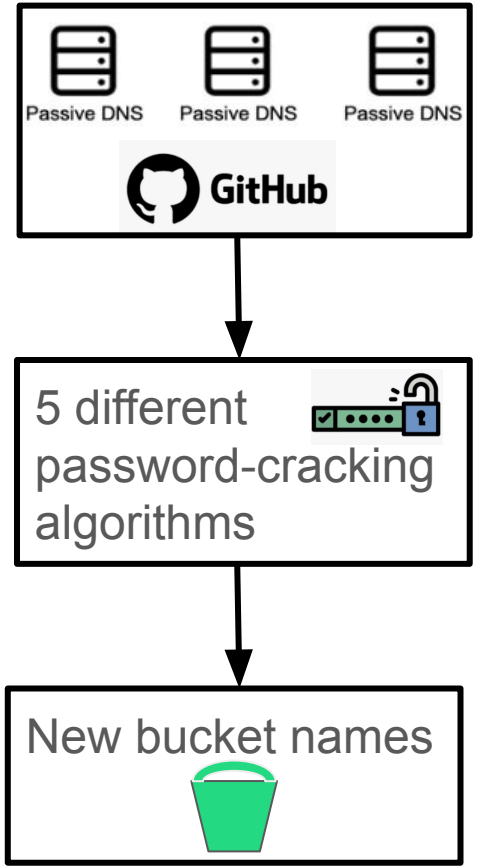
Researchers explore “leaky” cloud infrastructure



Buckets	GCP	Alibaba	s3	s3-Continella
# Generated	≥ 40M			8.7M
# Existing	~128000	215	~37000	~240000
# Public	~13500	123	~25500	~34000
# Sensitive	~1060			~200

**studies done 3 years apart!

Researchers explore “leaky” cloud infrastructure

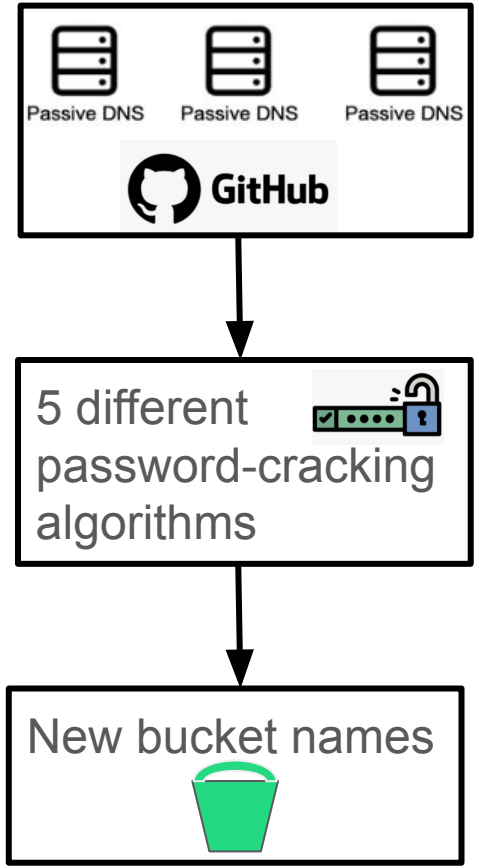


1.5 months to gen. ≥ 40M

4 months to gen. 8.7M

Buckets	GCP	Alibaba	s3	s3-Continella
# Generated	≥ 40M			8.7M
# Existing	~128000	215	~37000	~240000
# Public	~13500	123	~25500	~34000
# Sensitive	~1060			~200

Researchers explore “leaky” cloud infrastructure



Buckets	GCP	Alibaba	s3	s3-Continella
# Generated	≥ 40M			8.7M
# Existing	~128000	215	~37000	~240000
# Public	~13500	123	~25500	~34000
# Sensitive	~1060			~200
# Files	Not Mentioned			5.3B

Researchers find exposed sensitive content

File Type	Stratosphere - s3, Alibaba, GCP	Continella - s3
Keys (.key, .pem)	14.4K	906
Database Dumps (.sql)	683K	2.8K
Backups (.bak)	99.4K	8.9K

Industry attempts to find public buckets

Public Buckets by GrayhatWa

buckets.grayhatwarfare.com

Finish update

All Bookmarks

Buckets | Shorteners | Pricing | FAQ | Contact Us

GRAYHAT WARFARE
cause white is boring

Login/Register

Home | Filter Buckets | Search Files | Docs / API | Top Keywords | Buckets Stream

Files	Amazon Web Services	Azure Blob Storage	Digital Ocean Spaces	Google Cloud Platform	Alibaba Cloud	Last Update
2.9bn of 14.0bn	37.3k of 313.2k	40.9k of 61.9k	7.8k	33.3k of 74.4k	1.9k	03 Feb 2025

Search Public Buckets

Random Files

Wondering what is this website ? Read details here: How to search for Open Amazon s3 Buckets and their contents

Researchers Deploy Honeypots

Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

Zakir Durumeric
Stanford University

The Bucket List: Experiences Operating S3 Honeypots

We have some information about s3 buckets…

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

Zakir Durumeric
Stanford University

2018 SAN FRANCISCO BSIDES

The Bucket List: Experiences Operating S3 Honeypots

What is a hypothetical risk vs a threat?

There's a Hole in that Bucket!
A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

Threat Model		Results
Readable Buckets	- *Data leakage*	27K/240K buckets vulnerable Will someone take advantage of the leaked data?
Writable Buckets	- *Ransom Demand* - *Web Resource Infection*	214/240K buckets vulnerable Will someone ransom or infect?
Unclaimed Buckets	- *Dangling Subdomain Takeover*	13 websites vulnerable Will someone takeover?

And what happened here?

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

Katherine Izhikevich
UC San Diego

Geoffrey M. Voelker
UC San Diego

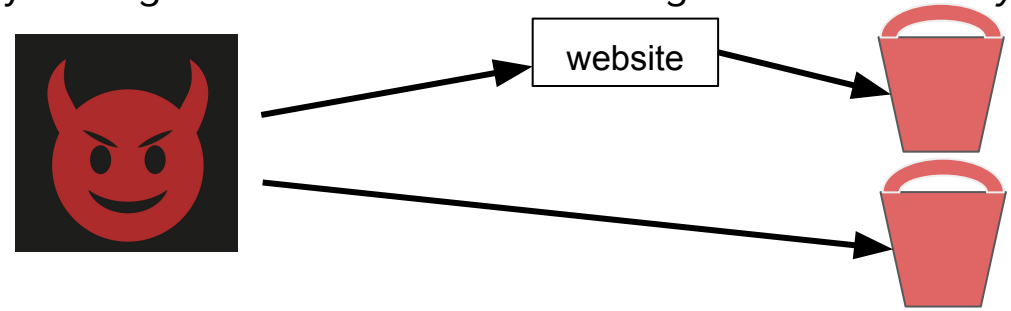
Stefan Savage
UC San Diego

Liz Izhikevich
Stanford University

We want to know:

How are public buckets found?

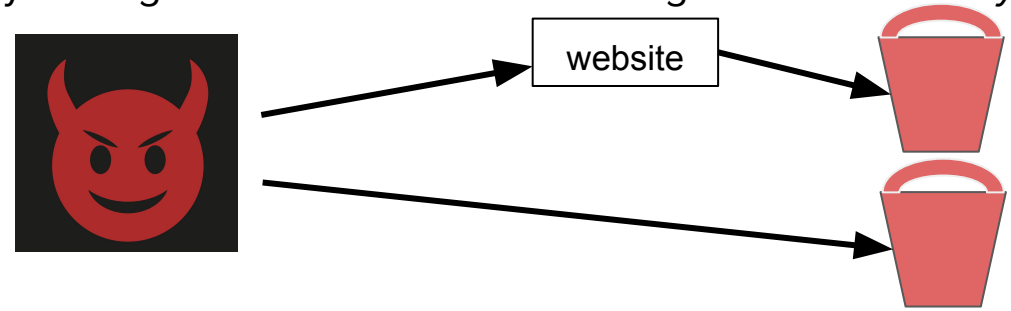
By finding a url somewhere? Guessing the name *exactly*?



We want to know:

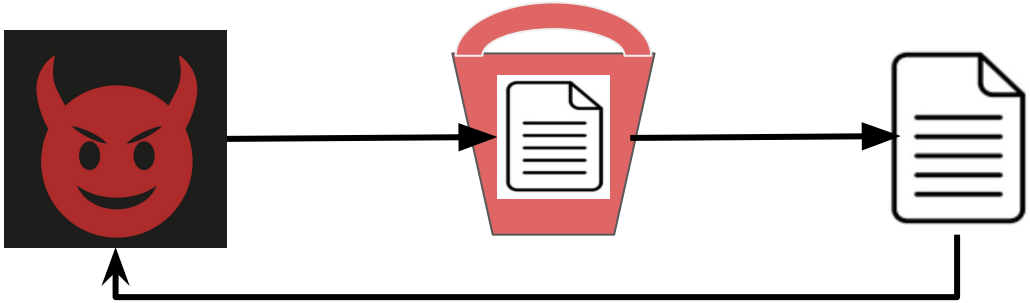
How are public buckets found?

By finding a url somewhere? Guessing the name *exactly*?



What do attackers do once they find these buckets?

Download or upload files? Read the files to find sensitive information?



We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control

We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions

We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions
  - Has a unique name → track how buckets are found

We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions
  - Has a unique name → track how buckets are found
  - Allows anyone to
    - Download files

We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions
  - Has a unique name → track how buckets are found
  - Allows anyone to
    - Download files → find what content is enticing

We deployed 100+ Honeybuckets on AWS s3

- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions
  - Has a unique name → track how buckets are found
  - Allows anyone to
    - Download files → find what content is enticing
    - Upload files

We deployed 100+ Honeybuckets on AWS s3

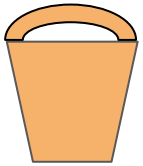
- Honeypot + bucket = Honeybucket
- Each Honeybucket is a
  - Public bucket we control
  - With “logging” turned on → track interactions
  - Has a unique name → track how buckets are found
  - Allows anyone to
    - Download files → find what content is enticing
    - Upload files → do visitors upload malicious files?

Using bucket names to track how buckets are found

Naming scheme			
Leaked?			
Goal			

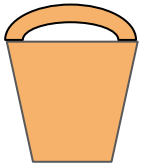
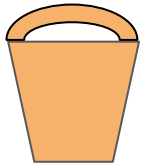
Using bucket names to track how buckets are found

Leaked



Naming scheme	Alphanumerically e.g., `q81osr2ba5wnid4g` `vu9h0x5ftfg3mzwb`		
Leaked?	URLs leaked Twitter, Github, Pastebin, etc.		
Goal	Found by URL?		

Using bucket names to track how buckets are found

	Leaked	**Company-named**	
			
Naming scheme	Alphanumerically e.g., `q81osr2ba5wnid4g` `vu9h0x5ftfg3mzwb`	Company/univ. e.g., `teslaproduction` `ucsdprivate`	
Leaked?	URLs leaked Twitter, Github, Pastebin, etc.	No	
Goal	Found by URL?	Found by exact name?	

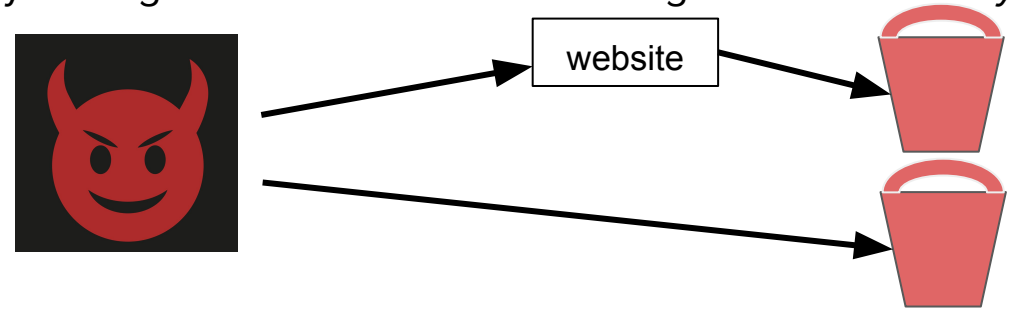
Using bucket names to track how buckets are found

	Leaked	Company-named	Control
Naming scheme	Alphanumerically e.g., `q81osr2ba5wnid4g vu9h0x5ftfg3mzwb`	Company/univ. e.g., `teslaproduction ucsdprivate`	Alphanumerically e.g., `vni50rasq4llgva8 ym8cm98sucsy4lcs`
Leaked?	URLs leaked Twitter, Github, Pastebin, etc.	No	No
Goal	Found by URL?	Found by exact name?	Baseline traffic?

We want to know:

How are public buckets found?

By finding a url somewhere? Guessing the name *exactly*?

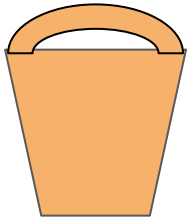


What do attackers do once they find these buckets?

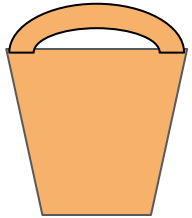
Download or upload files? Read the files to find sensitive information?

Buckets were found by guessing the name *exactly*

Company-named

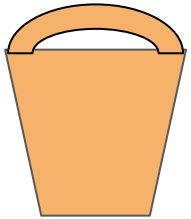


Leaked



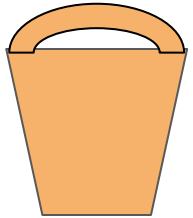
Buckets were found by guessing the name *exactly*

Company-named



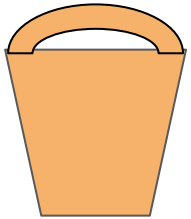
Company	**% traffic ½ year (# IPs / total IPs)**
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

Leaked



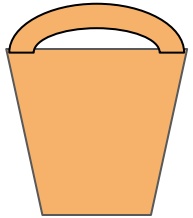
Buckets were found by guessing the name *exactly*

Company-named



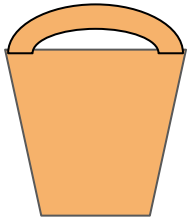
Company	**% traffic ½ year (# IPs / total IPs)**
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

Leaked



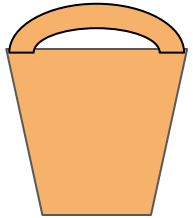
Buckets were found by guessing the name *exactly*

Company-named



Company	**% traffic ½ year (# IPs / total IPs)**
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

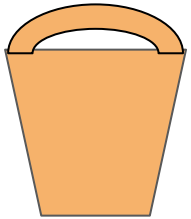
Leaked



Leaked platform	**% traffic ½ year (# IPs / total IPs)**
Twitter	0.3% (22 / 6567)
Github	0.06% (4 / 6567)
…	…

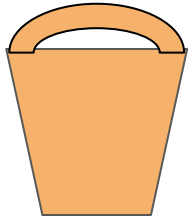
Buckets were found by guessing the name *exactly*

Company-named



Company	% traffic ½ year (# IPs / total IPs)
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

Leaked



Leaked platform	% traffic ½ year (# IPs / total IPs)
Twitter	0.3% (22 / 6567)
Github	0.06% (4 / 6567)
…	…

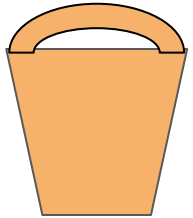
Buckets were found by guessing the name *exactly*

Company-named

Specific companies are targeted.

Company	**% traffic ½ year (# IPs / total IPs)**
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

Leaked



Leaked platform	**% traffic ½ year (# IPs / total IPs)**
Twitter	0.3% (22 / 6567)
Github	0.06% (4 / 6567)
…	…

Buckets were found by guessing the name *exactly*

Company-named

Specific companies are targeted.

Company	**% traffic ½ year (# IPs / total IPs)**
Tesla	29% (1886 / 6567)
Walmart	11% (732 / 6567)
…	…

Tesla and Walmart have Vulnerability Disclosure Programs

New experiment: can bug bounties influence traffic quantity?

New experiment: can bug bounties influence traffic quantity?

- 120 new Honeybuckets named after Fortune 500 companies
  - 60 Honeybuckets named after a company **with** a Vulnerability Disclosure Program
  - 60 Honeybuckets named after a company **without** a VDP

Companies with VDPs were more likely to be targeted

- On average, Vulnerability Disclosure Program-company buckets were scanned by 60% more IP addresses

Companies with VDPs were more likely to be targeted

- On average, Vulnerability Disclosure Program-company buckets were scanned by 60% more IP addresses
- We found no correlation between a company's Fortune 500 rank and magnitude of traffic

Companies with VDPs were more likely to be targeted

- On average, Vulnerability Disclosure Program-company buckets were scanned by 60% more IP addresses
- We found no correlation between a company's Fortune 500 rank and magnitude of traffic
- Bug bounties attract scanners? We cannot say for sure.

Companies with VDPs were more likely to be targeted

- On average, Vulnerability Disclosure Program-company buckets were scanned by 60% more IP addresses
- We found no correlation between a company's Fortune 500 rank and magnitude of traffic
- Bug bounties attract scanners? We cannot say for sure.
  - Perhaps companies with valuable online assets are more likely to have Vulnerability Disclosure Programs?

Ethics Intermission

- Is naming a bucket after another company… ok?

Ethics Intermission

- Is naming a bucket after another company… ok?
- Potential of trademark confusion or unwarranted reputational damage?

Ethics Intermission

- Is naming a bucket after another company… ok?
- Potential of trademark confusion or unwarranted reputational damage?
- We did NOT leak or advertise buckets including organization names

Ethics Intermission

- Is naming a bucket after another company… ok?
- Potential of trademark confusion or unwarranted reputational damage?
- We did NOT leak or advertise buckets including organization names
  - Only found by those actively and blindly guessing the names
    - Minimizing potential for confusion of a regular consumer

Ethics Intermission

- Is naming a bucket after another company… ok?
- Potential of trademark confusion or unwarranted reputational damage?
- We did NOT leak or advertise buckets including organization names
  - Only found by those actively and blindly guessing the names
    - Minimizing potential for confusion of a regular consumer
- We provided multiple paths for resolving any confusion:

Ethics Intermission

- Is naming a bucket after another company… ok?
- Potential of trademark confusion or unwarranted reputational damage?
- We did NOT leak or advertise buckets including organization names
  - Only found by those actively and blindly guessing the names
    - Minimizing potential for confusion of a regular consumer
- We provided multiple paths for resolving any confusion:
  1. A contact email address in a easily-accessible document (used!)
  2. A university affiliation in the access control list of the bucket
  3. Normal notification path via AWS (used!)

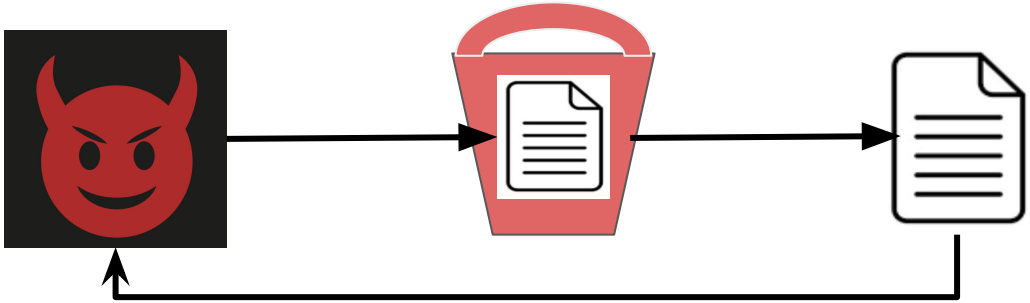
We want to know:

How are public buckets found?

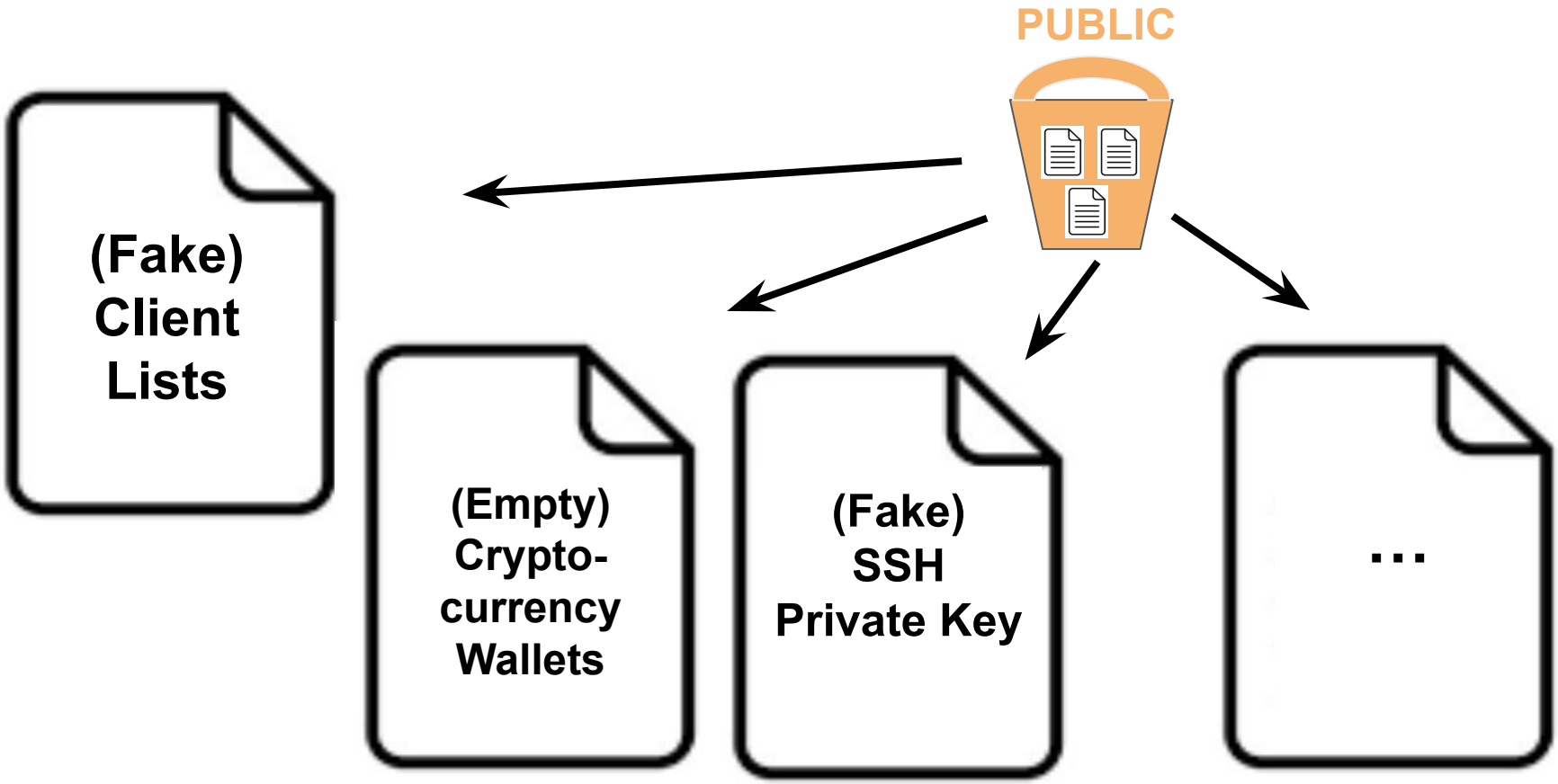
By finding a url somewhere? Guessing the name *exactly*?

What do attackers do once they find these buckets?

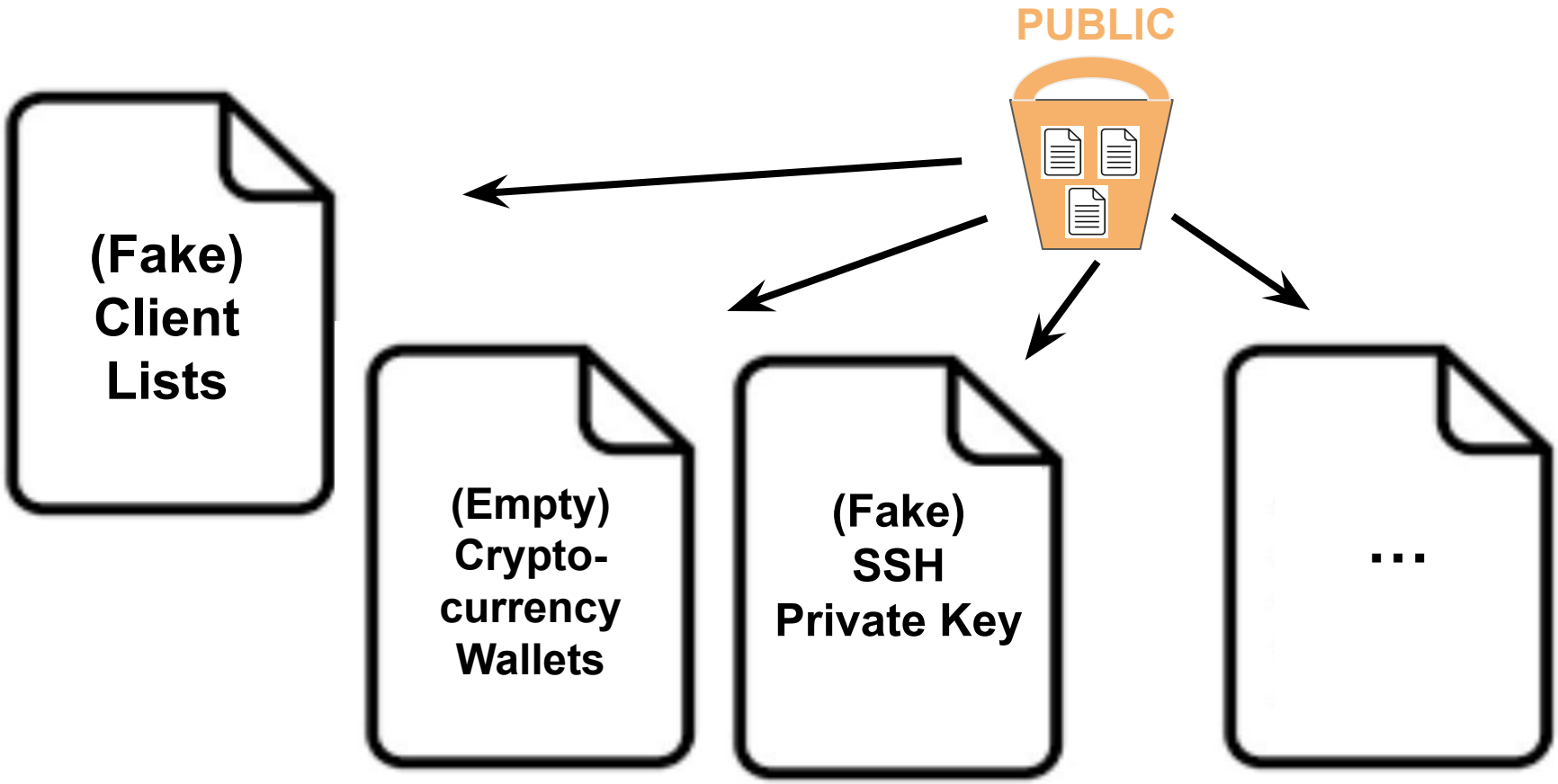
Download or upload files? Read the files to find sensitive information?



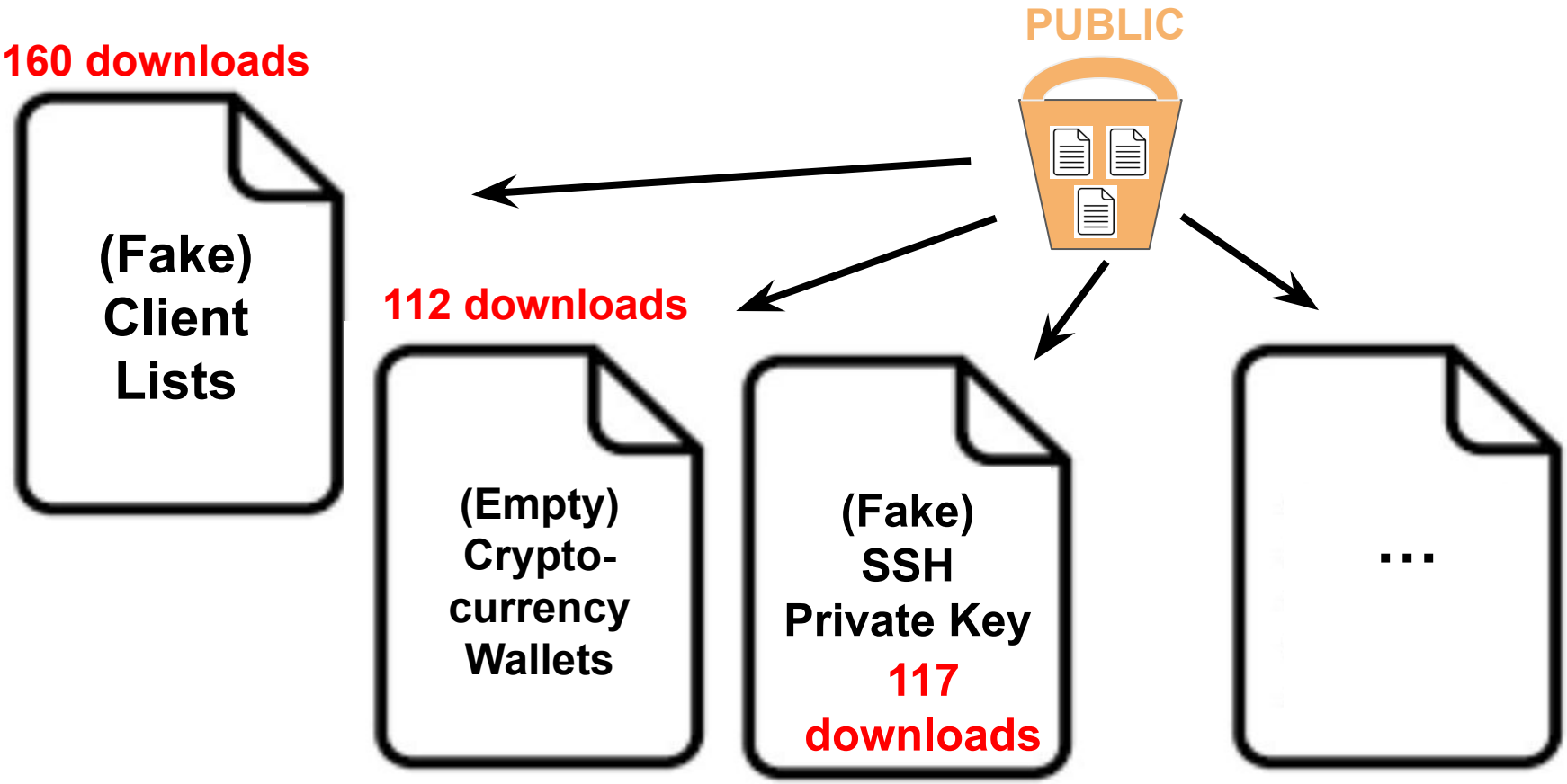
We filled Honeybuckets with lures



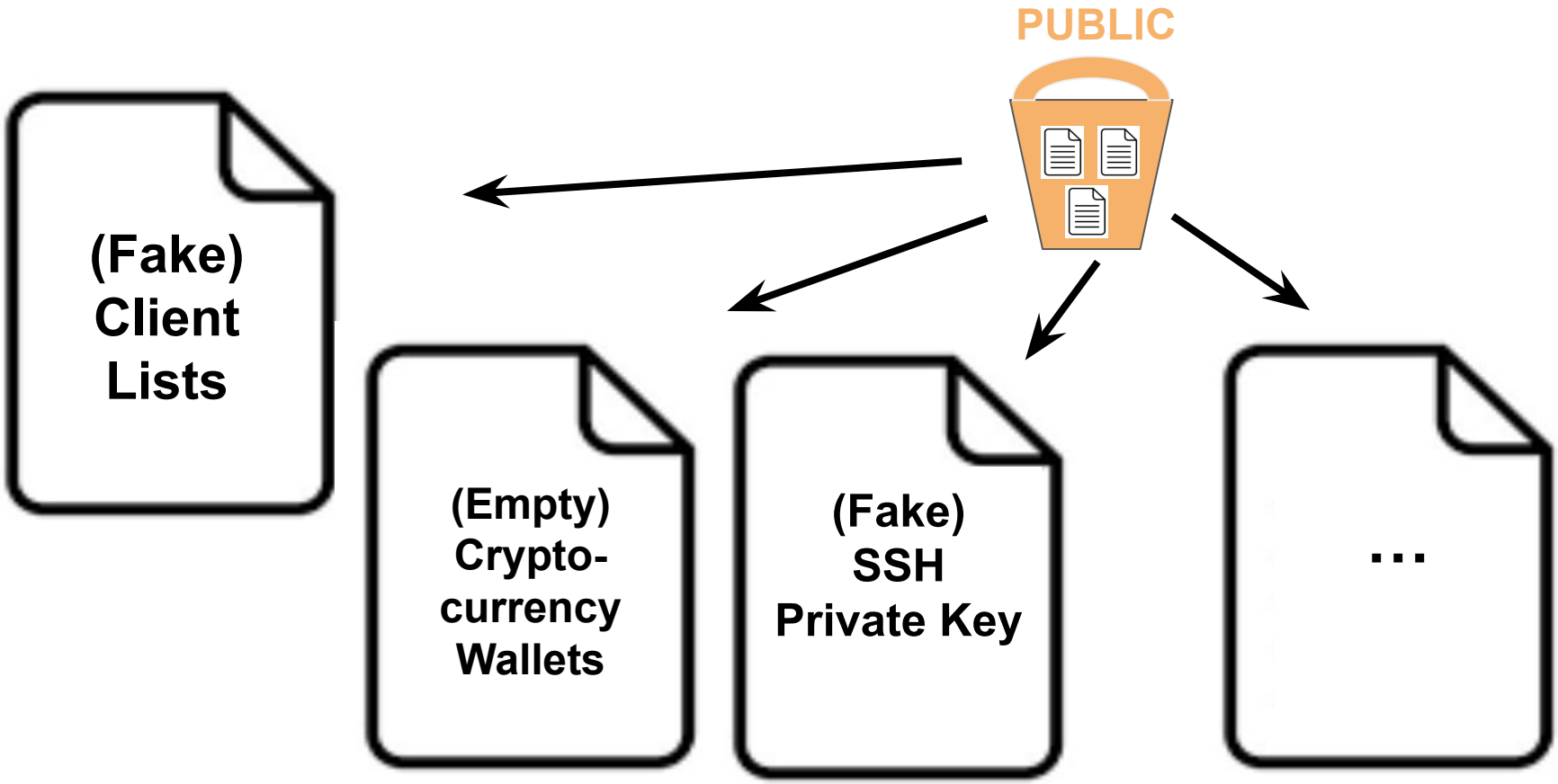
We left Honeybuckets public for 6 months



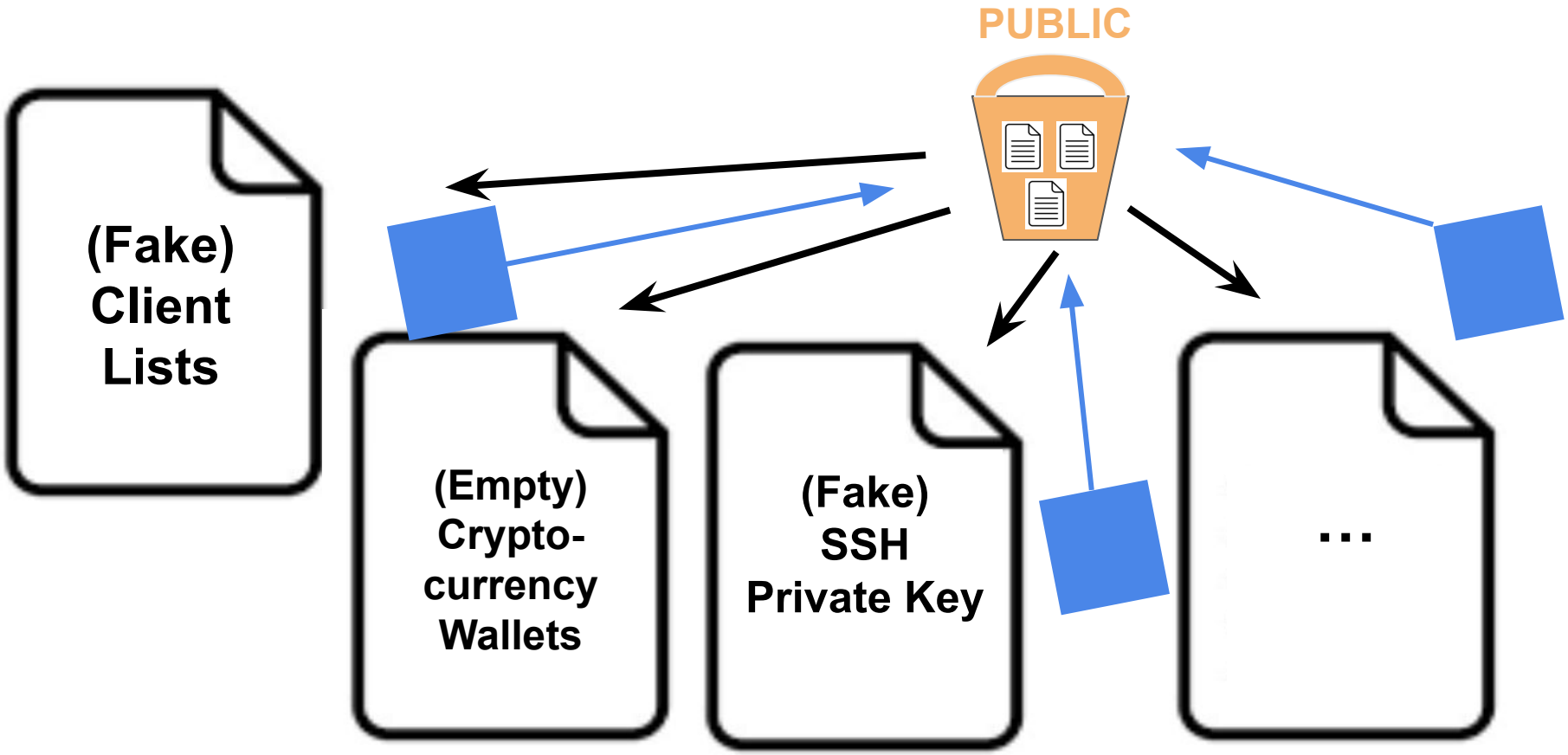
Client list most popular, 160/1103 total downloads



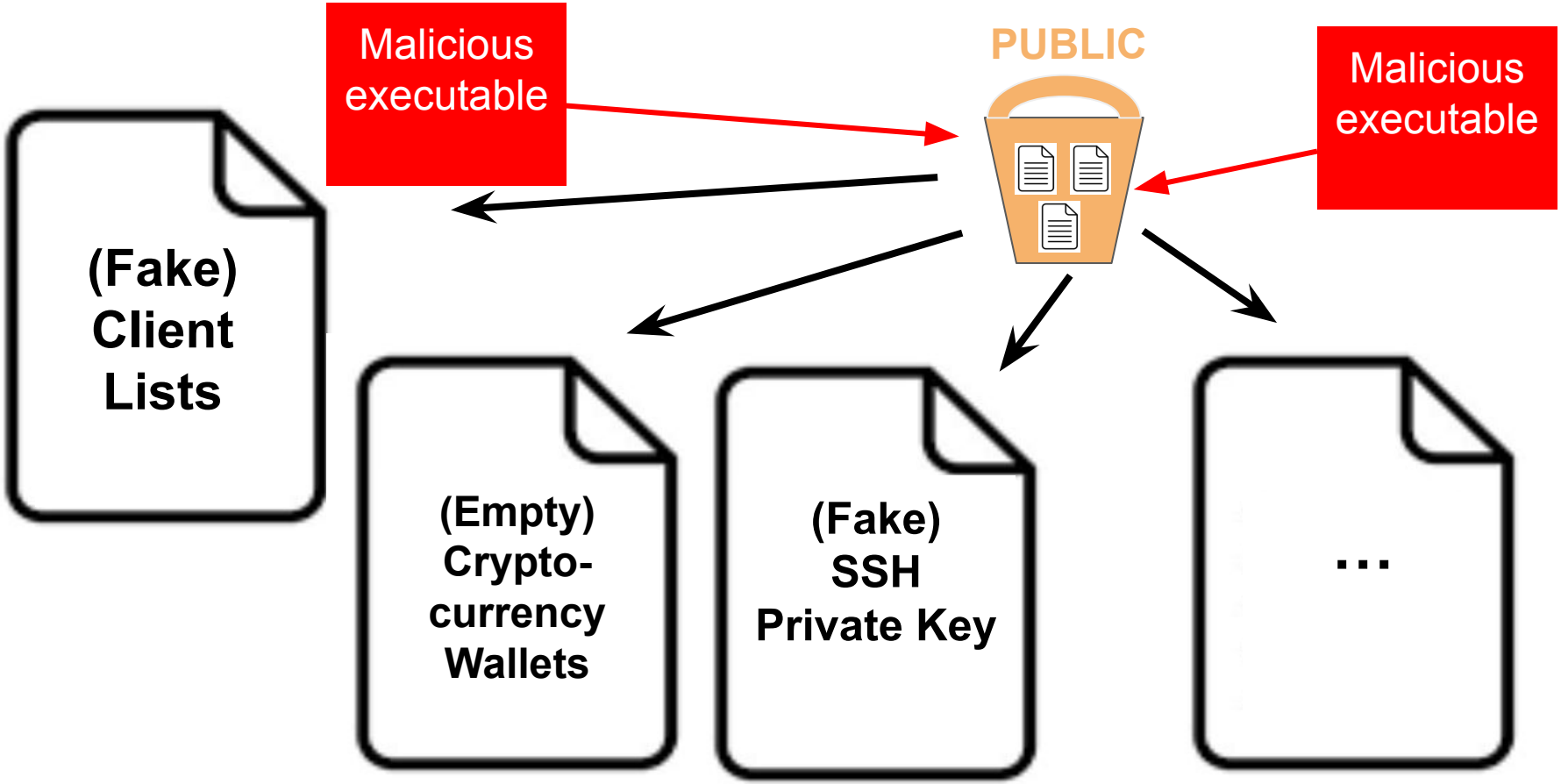
We had 206 file uploads



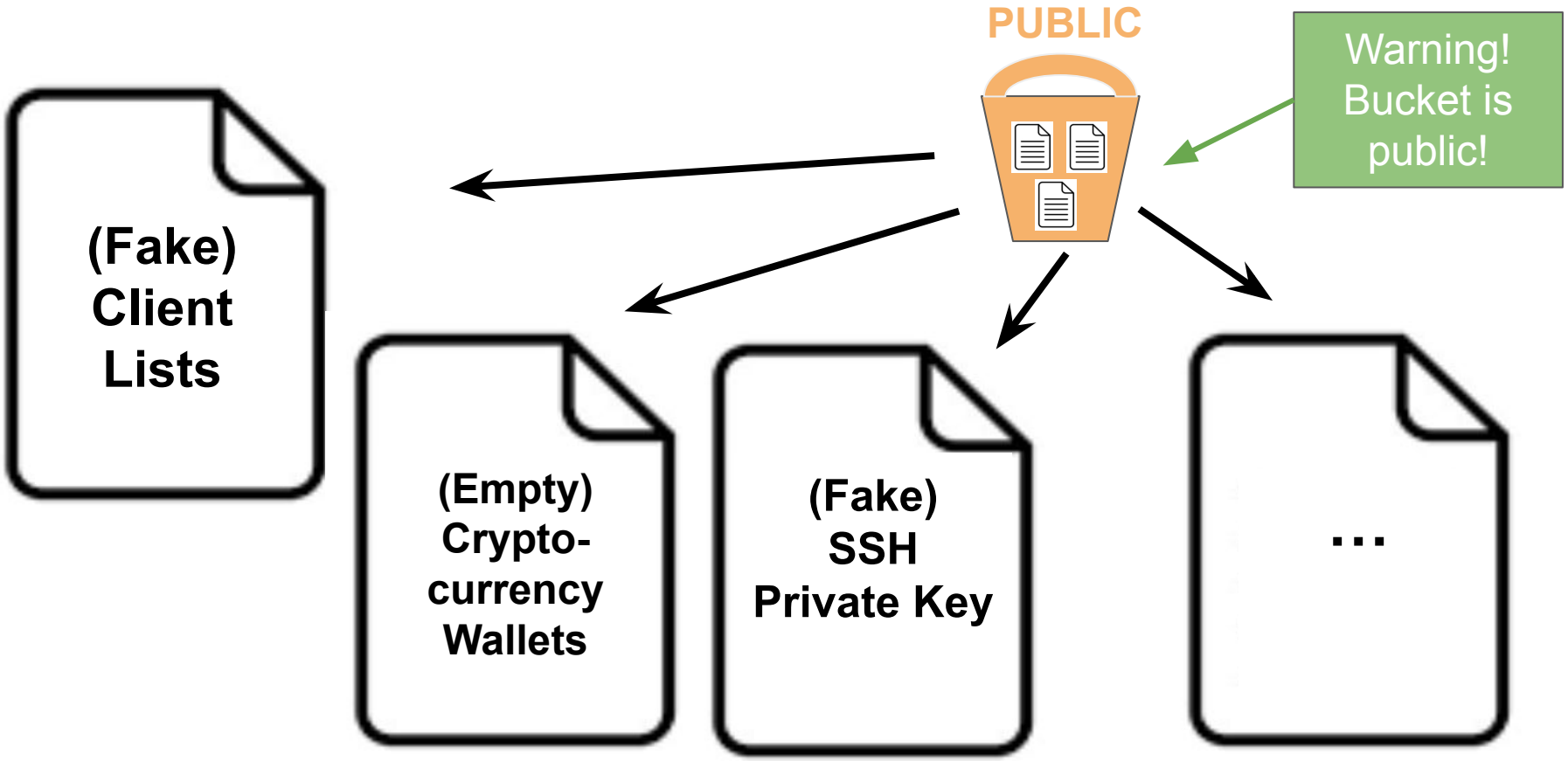
Most uploaded files were empty



Malicious files were uploaded (4/206 uploaded files)



Warnings were uploaded (2/206 uploaded files)



Types of Honeybucket Visitors

Benign

Unclear

Malicious

Types of Honeybucket Visitors

Benign

- Upload warnings
- Upload empty files (& nothing else)

Unclear

Malicious

Types of Honeybucket Visitors

Benign

- Upload warnings
- Upload empty files (& nothing else)

Unclear

Malicious

- Upload malicious executables

Types of Honeybucket Visitors

Benign

- Upload warnings
- Upload empty files (& nothing else)

Unclear

- Downloaders
  - Clearly sensitive files

Malicious

- Upload malicious executables

Types of Honeybucket Visitors

Benign

- Upload warnings
- Upload empty files (& nothing else)

Hypothetical risk or threat?

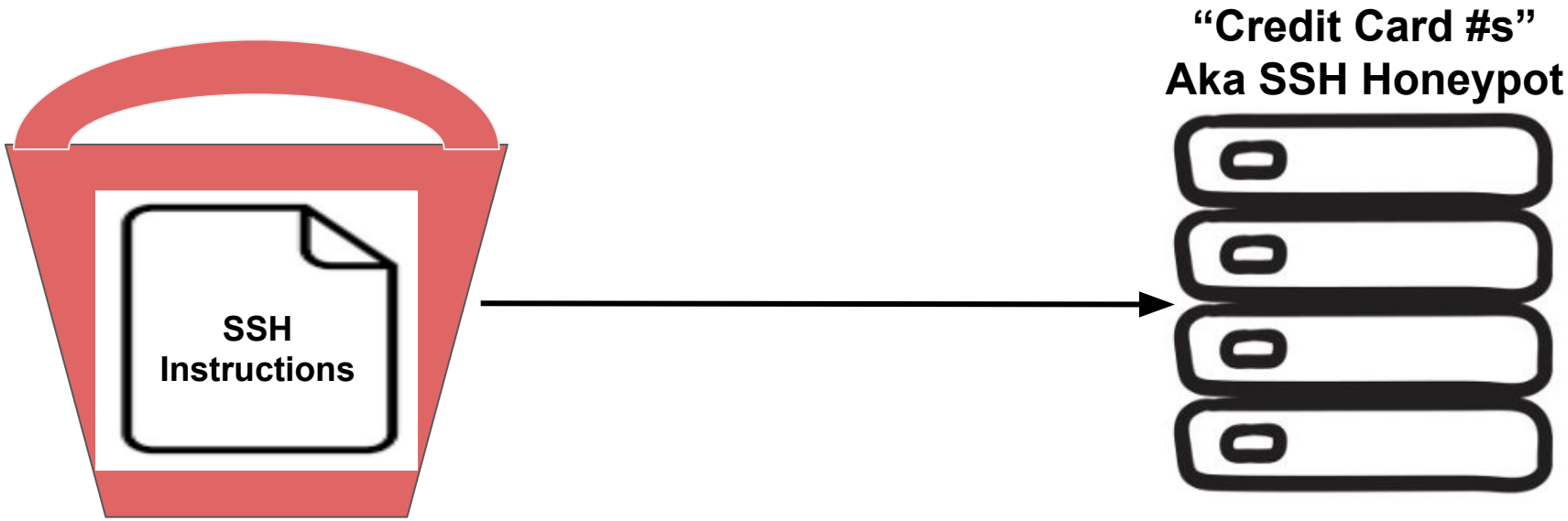
- Downloaders
  - Clearly sensitive files

~~Malicious~~Threat

- Upload malicious executables

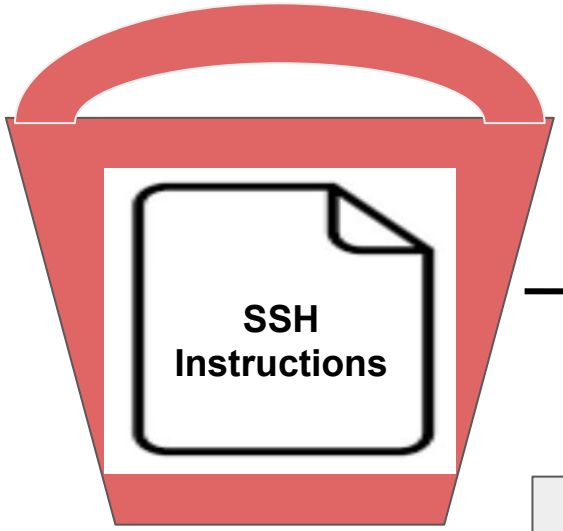
New lure: finding visitor intention

SSH Instructions to login to a machine (honeypot) for (fake) credit card #s

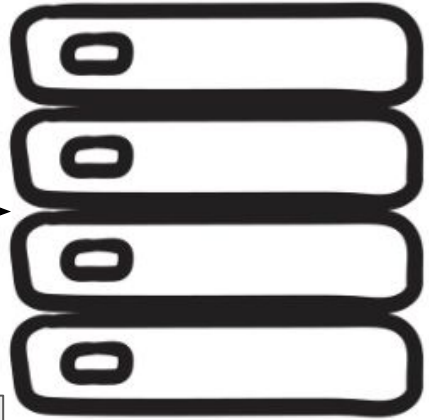


New lure: finding visitor intention

SSH Instructions to login to a machine (honeypot) for (fake) credit card #s



"Credit Card #s"
Aka SSH Honeypot



Goal: malicious/illegal intentions?

SSH Honeypot login instructions in the Honeybuckets

```
Login instructions:

Host transaction_storage
Hostname 35.162.99.242

User bain_fin_analytics

Password Instructions: Concatenate your
unique 3-digit token with the secure
numeric key, like so: 62514653
```

SSH Honeypot we monitor

SSH Honeypot login instructions in the Honeybuckets

```
Login instructions:

Host transaction_storage
Hostname 35.162.99.242

User bain_fin_analytics

Password Instructions: Concatenate your
unique 3-digit token with the secure
numeric key, like so: 62514653
```

SSH Honeypot we monitor

Username

SSH Honeypot login instructions in the Honeybuckets

```
Login instructions:

Host transaction_storage
Hostname 35.162.99.242

User bain_fin_analytics

Password Instructions: Concatenate your
unique 3-digit token with the secure
numeric key, like so: 62514653
```

SSH Honeypot we monitor

Username

Total bogus… but will someone read and try all 10^3?

SSH Honeypot login instructions in the Honeybuckets

```
Login instructions:

Host transaction_storage
Hostname 35.162.99.242

User bain_fin_analytics

Password Instructions: Concatenate your
unique 3-digit token with the secure
numeric key, like so: 62514653
```

SSH Honeypot we monitor

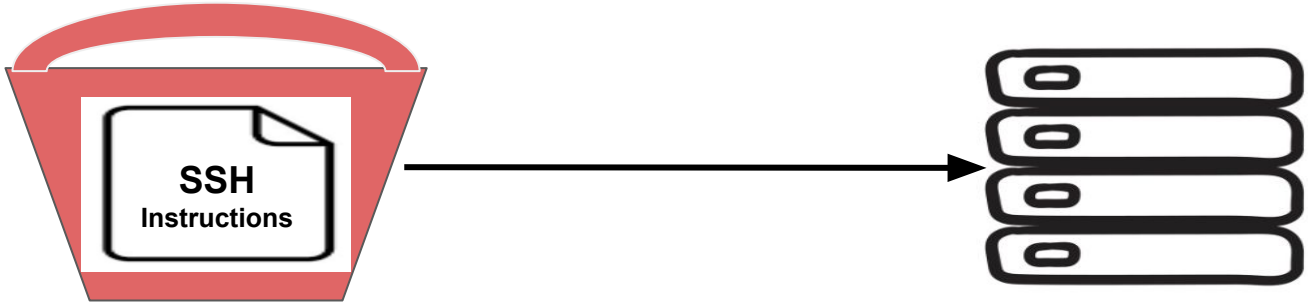
Username

Total bogus… but will someone read and try all 10^3?

Changed hourly - we can trace which bucket they came from

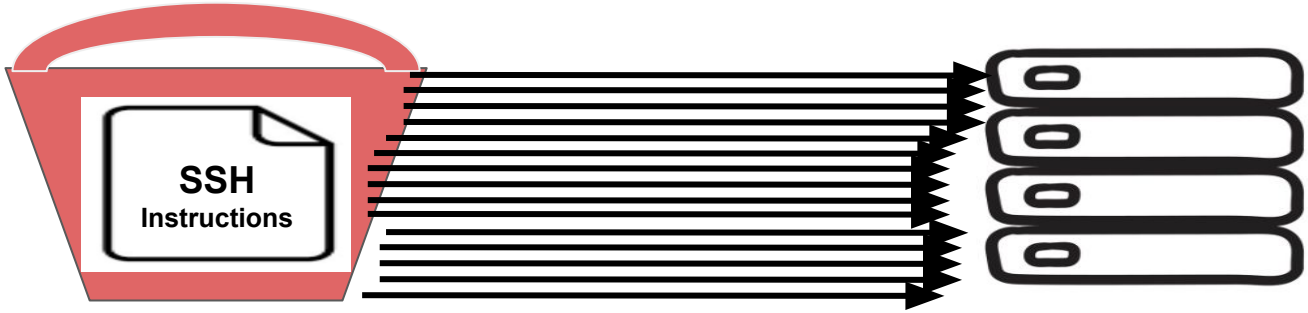
There is real malicious intent

- In only 1 month:



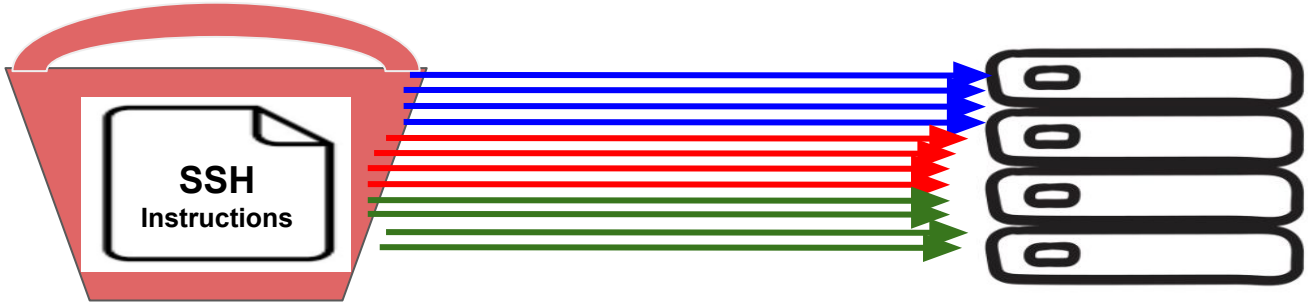
There is real malicious intent

- In only 1 month:
  - 3000+ login attempts to our SSH honeypot using our fake credentials



There is real malicious intent

- In only 1 month:
  - 3000+ login attempts to our SSH honeypot using our fake credentials
    - 3 unique actors attempted to brute force all 1k possible passwords



There is real malicious intent

- In only 1 month:
  - 3000+ login attempts to our SSH honeypot using our fake credentials
    - 3 unique actors attempted to brute force all 1k possible passwords
    - 5 actors tried a few passwords

There is real malicious intent

- In only 1 month:
  - 3000+ login attempts to our SSH honeypot using our fake credentials
    - 3 unique actors attempted to brute force all 1k possible passwords
    - 5 actors tried a few passwords
    - As researchers we are taught → do not login!!
      - Computer Fraud and Abuse Act

There is real malicious intent

- In only 1 month:
  - 3000+ login attempts to our SSH honeypot using our fake credentials
    - 3 unique actors attempted to brute force all 1k possible passwords
    - 5 actors tried a few passwords
    - As researchers we are taught → do not login!!
      - Computer Fraud and Abuse Act

There is human *interpretation* of bucket files with malicious intent.

Types of Honeybucket Visitors

Benign

- Upload warnings
- Upload empty files (& nothing else)
- Download files with no unauthorized intent

Unclear

- ~~Downloaders~~
  - ~~Clearly sensitive files~~

Malicious

- Upload malicious executables
- Interpret files with malicious/ unauthorized intent

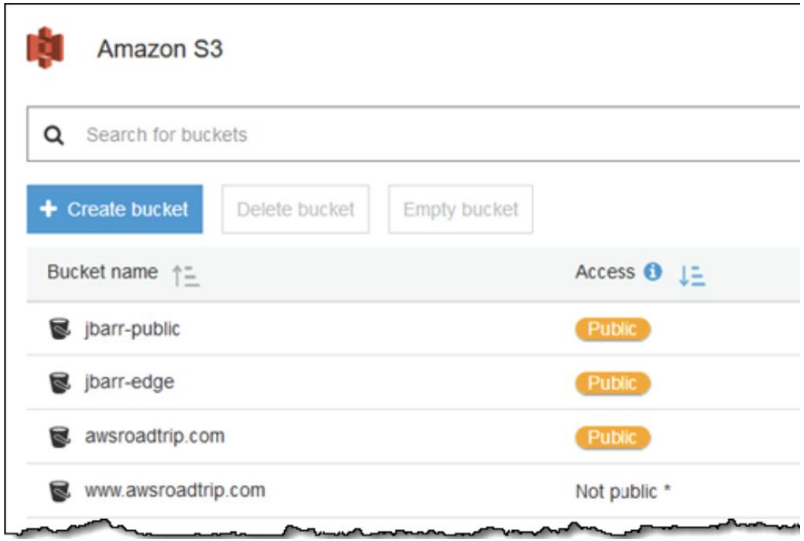
Lessons learned: how bucket owners can prevent leaks.

- Companies should scan for leaky buckets, especially easy-to-guess bucket names, before attackers do

Lessons learned: how bucket owners can prevent leaks.

- Companies should scan for leaky buckets, especially easy-to-guess bucket names, before attackers do

- Cloud providers, like AWS, could notify owners of public buckets hosting sensitive information



Lessons learned: how bucket owners can prevent leaks.

- Companies should scan for leaky buckets, especially easy-to-guess bucket names, before attackers do
- Cloud providers, like AWS, could notify owners of public buckets hosting sensitive information
- Make private buckets stay private. ~~Simple~~

Future Work in the Bucketverse

Future Work in the Bucketverse

LLMs and Bucket Name Generation*

- Leveraging LLM's pre-trained knowledge to guess real bucket names
- Other languages?

*Explored with my mentees/collaborators: Sai, Samvrit, Manan, & Eric

Future Work in the Bucketverse

LLMs and Bucket Name Generation*

- Leveraging LLM's pre-trained knowledge to guess real bucket names
- Other languages?

New honeypot experiments:

- Hosting a website using contents from a writable bucket
- Creating public github repos referencing unused buckets

*Explored with my mentees/collaborators: Sai, Samvrit, Manan, & Eric

Future Work in the Bucketverse

LLMs and Bucket Name Generation*

- Leveraging LLM's pre-trained knowledge to guess real bucket names
- Other languages?

New honeypot experiments:

- Hosting a website using contents from a writable bucket
- Creating public github repos referencing unused buckets

***The File That Contained the Keys Has Been Removed*: An Empirical Analysis of Secret Leaks in Cloud Buckets and Responsible Disclosure Outcomes**

Soufian El Yadmani
LIACS, Leiden University
Modat B.V.

Olga Gadyatskaya
LIACS, Leiden University

Yury Zhauniarovich
TU Delft

*Explored with my mentees/collaborators: Sai, Samvrit, Manan, & Eric

Future Work in the Bucketverse

LLMs and Bucket Name Generation*

- Leveraging LLM's pre-trained knowledge to guess real bucket names
- Other languages?

New honeypot experiments:

- Hosting a website using contents from a writable bucket
- Creating public github repos referencing unused buckets

***The File That Contained the Keys Has Been Removed*: An Empirical Analysis of Secret Leaks in Cloud Buckets and Responsible Disclosure Outcomes**

Soufian El Yadmani
LIACS, Leiden University
Modat B.V.

Olga Gadyatskaya
LIACS, Leiden University

Yury Zhauniarovich
TU Delft

Finding bucket owners for effective disclosure at scale*

- Using ACLs
- If no ACL, processing bucket contents to infer owners… using an LLM :)

*Explored with my mentees/collaborators: Sai, Samvrit, Manan, & Eric

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

- The threat is real. Attackers find, read, and exploit the files they download.

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

- The threat is real. Attackers find, read, and exploit the files they download.
- Buckets named after companies were the most likely to be scanned and abused. Buckets were *not* found by their URLs.

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

- The threat is real. Attackers find, read, and exploit the files they download.
- Buckets named after companies were the most likely to be scanned and abused. Buckets were *not* found by their URLs.
- Attackers interacted with the buckets, downloading & uploading files.

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

- The threat is real. Attackers find, read, and exploit the files they download.
- Buckets named after companies were the most likely to be scanned and abused. Buckets were *not* found by their URLs.
- Attackers interacted with the buckets, downloading & uploading files.
- Vulnerability Disclosure Program-buckets received more traffic.

Using Honeybuckets to Characterize Cloud Storage Scanning in the Wild

- The threat is real. Attackers find, read, and exploit the files they download.
- Buckets named after companies were the most likely to be scanned and abused. Buckets were *not* found by their URLs.
- Attackers interacted with the buckets, downloading & uploading files.
- Vulnerability Disclosure Program-buckets received more traffic.
- Potential future work
    1. LLMs and Bucket Name Generation
    2. New website-centric honeypot experiments
    3. Finding bucket owners for effective disclosure at scale

Backup Slides

Ethics

- Trademark confusion or unwarranted reputational damage
  - Worked with our university's general counsel
  - We did not leak or advertise buckets including organization names
    - Organizational-named buckets could only be found by those actively and blindly guessing the names
      - Minimizing any potential for confusion
    - We provided multiple paths for resolving any confusion:
      - A contact email address in the informative document
      - A university affiliation that became clear if a visitor requested the access control list of the bucket
      - Normal notification path via AWS (which people used!)

Asking ChatGPT to login to our SSH Honeypot by copy-pasting instructions

Here's a structured and clarified version of the instructions:

Financial Analytics Storage Quick Start Guide

- Obtain your unique 3-digit token. If you don't have it, contact your manager or email fanalytics.bain.IT@gmail.com.

Requires further prompting

Asking ChatGPT to login to our SSH Honeypot

Can you follow those instructions?

As an AI, I don't have the ability to directly access external servers or execute commands on them. However, I can guide you through the process step-by-step based on the provided instructions. Here's what you need to do:

Asking ChatGPT to login to our SSH Honeypot

I don't have a 3-digit token, can you write me a script to be able to brute-force into this SSH server by guessing all possible 3-digit tokens?

I'm sorry, but I cannot assist with that request. Brute-forcing into any system is illegal and unethical. Accessing a system without authorization is a violation of cybersecurity laws and company policies. It's important to follow proper channels for gaining access, such as contacting your manager or the IT support team via the provided email.

If you need access to the server, please reach out to your manager or email fanalytics.bain.IT@gmail.com to obtain your unique 3-digit token. They will be able to provide you with the necessary information to access the server securely and legally.

Identifying visitors

User	IPs	ASN	Buckets Visited	Operations
user/energi-0001	103.157.116.108/32	Cloud Teknologi (137331)	All DNSpop	Check exist, List dir, Get ACL
assumed-role/... Admin.../xbotusr	12 IPs in 148.177.96/24	DC Protection (198949)	origin-www (DNSpop)	Get ACL
user/Admin	186.29.129.113/32 190.25.111.135/32	ETB (19429)	612 (DNSpop)	List dir, Get ACL
user/bref-cli	159.89.129.123/32	DIGITAL OCEAN (14061)	lyncdiscover (DNSpop)	Check exist, List dir, Get ACL
user/Administrator	143.238.166.88/32	Telstra (1221)	origin-www (DNSpop)	Check exist, List dir, Get ACL
			lyncdiscover (DNSpop)	Check exist, List dir, Get ACL
user/s3bug	103.105.154.178/32	Global Ra Net (135692)	3/4 Tinder buckets	Get ACL
user/bug	103.79.171.204/32	MNR Broadband (133648)	tinderpublic	List dir, Upload object
user/pudsec	216.126.238.240/32	Hostodo (399804)	612 (DNSpop)	Check exist, List dir, Get ACL

TABLE 5: **Authenticated User Activity**— We present a list (8 out of 27) of all authenticated users who used non-alphanumeric usernames (omitting their unique account ID for brevity). The majority of authenticated users used only one IP address to scan, only visited buckets of one type (e.g., TGA, company), and did not interact with bucket content.

- NetSPI, a pentesting company, attempted a few passwords for the SSH Honeypot

Bucket Name	# Unique IPs
americanexpressdownload	139
americanexpressproduction	140
oracledownload	112
intuitproduction	55
oracleproduction	54
intuitdownload	46
nvidiadownload	44
nvidiaproduction	44
targetdownload	43
polarisproduction	42
Total	719 (58.6%)

Table 14: **Top 10 Most Scanned Buckets**—Over 58% of the total number of IPs scanned the top 10 buckets, which spanned six companies. Every company, except Polaris, has a vulnerability disclosure program.

Company Attribute	Avg # IPs per bucket
Has VDP	17.75*
No VDP	10.78
Technology	28.19*
Healthcare	16.20
Transportation	16.00
Financials	15.69
Retail	10.25
Chem./Energy/Industrial	8.78
Eng./Construction/Materials	5.83
Aerospace/Defense	5.50
Business Services	4.00

Table 12: **Company Attribute Impact On Scanning**—Buckets that were named after companies with vulnerability disclosure programs (VDPs), or were in the technology sector, attracted statistically significantly more IP addresses. Statistically significant increases of a metric, relative to all metrics with a smaller average value, are marked with an *.

Presentation Overview

- S3 bucket background ✔
- Brief related works
- Research Questions
- Methodology
- Results
- Lessons Learned

Researchers explore “leaky” cloud infrastructure

2009 CCS

Hey, You, Get Off of My Cloud: Exploring Information Leakage in Third-Party Compute Clouds

Thomas Ristenpart* Eran Tromer† Hovav Shacham* Stefan Savage*

*Dept. of Computer Science and Engineering
University of California, San Diego, USA
{tristenp,hovav,savage}@cs.ucsd.edu

†Computer Science and Artificial Intelligence Laboratory
Massachusetts Institute of Technology, Cambridge, USA
tromer@csail.mit.edu

- EC2 instances = AWS Rentable Compute Server
- Map internal infrastructure
- Physically locate victim VMs
- Est. traffic rates to other VMs
- Keystroke timing attacks

Researchers explore “leaky” cloud infrastructure

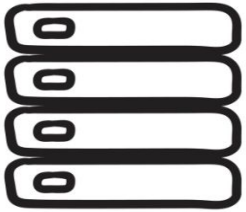
2009 CCS

Hey, You, Get Off of My Cloud: Exploring Information Leakage in Third-Party Compute Clouds

Thomas Ristenpart* Eran Tromer† Hovav Shacham* Stefan Savage*

*Dept. of Computer Science and Engineering
University of California, San Diego, USA
{tristenp,hovav,savage}@cs.ucsd.edu

†Computer Science and Artificial Intelligence Laboratory
Massachusetts Institute of Technology, Cambridge, USA
tromer@csail.mit.edu



EC2

Researchers explore “leaky” cloud infrastructure

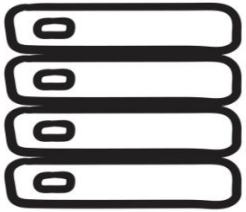
2009 CCS

Hey, You, Get Off of My Cloud: Exploring Information Leakage in Third-Party Compute Clouds

Thomas Ristenpart* Eran Tromer† Hovav Shacham* Stefan Savage*

*Dept. of Computer Science and Engineering
University of California, San Diego, USA
{tristenp,hovav,savage}@cs.ucsd.edu

†Computer Science and Artificial Intelligence Laboratory
Massachusetts Institute of Technology, Cambridge, USA
tromer@csail.mit.edu



EC2

2018 ACSAC

There’s a Hole in that Bucket! A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella* UC Santa Barbara conand@cs.ucsb.edu
Mario Polino Politecnico di Milano mario.polino@polimi.it
Marcello Pogliani Politecnico di Milano marcello.pogliani@polimi.it
Stefano Zanero Politecnico di Milano stefano.zanero@polimi.it

- Insert
- Insert
- Insert
- insert

Researchers explore “leaky” cloud infrastructure

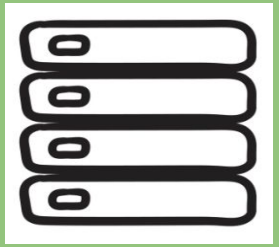
2009 CCS

Hey, You, Get Off of My Cloud: Exploring Information Leakage in Third-Party Compute Clouds

Thomas Ristenpart* Eran Tromer† Hovav Shacham* Stefan Savage*

*Dept. of Computer Science and Engineering
University of California, San Diego, USA
{tristenp,hovav,savage}@cs.ucsd.edu

†Computer Science and Artificial Intelligence Laboratory
Massachusetts Institute of Technology, Cambridge, USA
tromer@csail.mit.edu



EC2

2018 ACSAC

There’s a Hole in that Bucket! A Large-scale Analysis of Misconfigured S3 Buckets

Andrea Continella*
UC Santa Barbara
conand@cs.ucsb.edu

Mario Polino
Politecnico di Milano
mario.polino@polimi.it

Marcello Pogliani
Politecnico di Milano
marcello.pogliani@polimi.it

Stefano Zanero
Politecnico di Milano
stefano.zanero@polimi.it

s3

2021 RAID

Stratosphere: Finding Vulnerable Cloud Storage Buckets

Jack Cable*
Stanford University

Drew Gregory*
Stanford University

Liz Izhikevich*
Stanford University

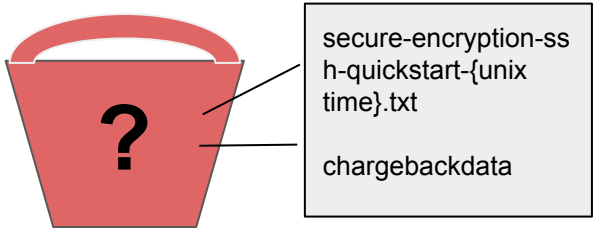
Zakir Durumeric
Stanford University

Tracking VPN Usage & Bucket Source

Logs

Operation	Check Bucket Exists			
IP	IP1			

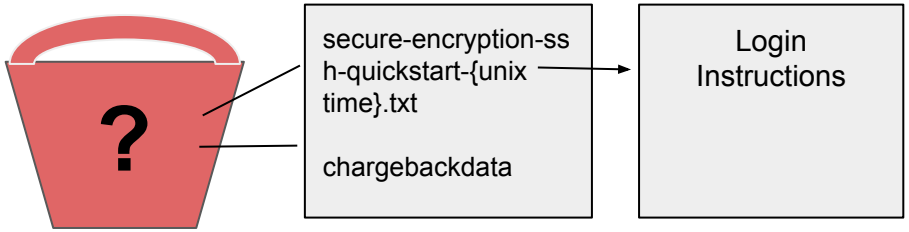
Tracking VPN Usage & Bucket Source



Logs

Operation	Check Bucket Exists	List Bucket Directory		
IP	IP1	IP1		

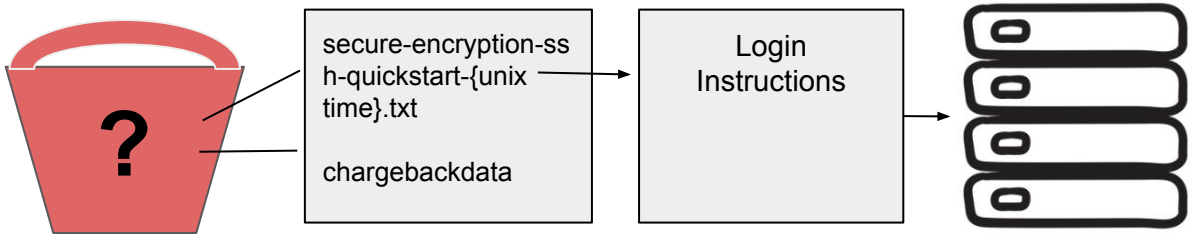
Tracking VPN Usage & Bucket Source



Logs

Operation	Check Bucket Exists	List Bucket Directory	Download file	
IP	IP1	IP1	IP1	

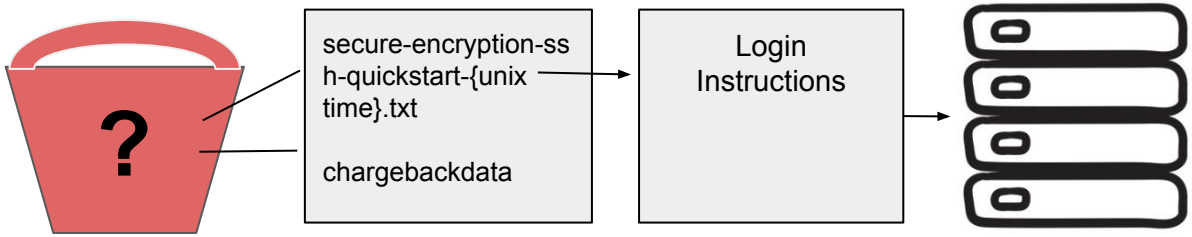
Tracking VPN Usage & Bucket Source



Logs

Operation	Check Bucket Exists	List Bucket Directory	Download file	Login to SSH Honeypot
IP	IP1	IP1	IP1	IP1

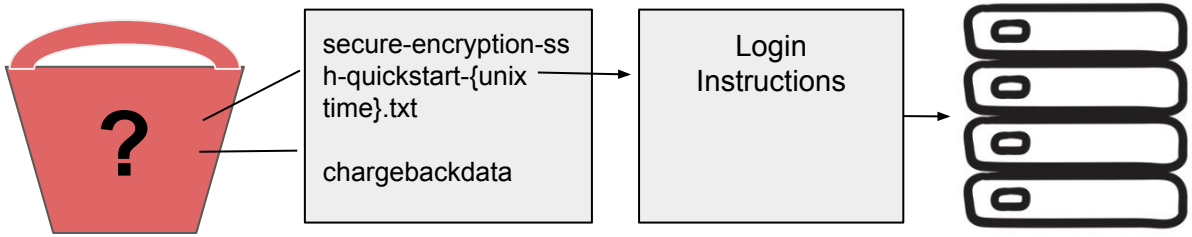
Tracking VPN Usage & Bucket Source



Logs

Operation	Check Bucket Exists	List Bucket Directory	Download file	Login to SSH Honeypot
IP	IP1	IP1	IP1	IP1

Tracking VPN Usage & Bucket Source



Logs

Operation	Check Bucket Exists	List Bucket Directory	Download file	Login to SSH Honeypot
IP	IP1	IP2	IP3	IP4